

Customer Support Q&A API

Node.js 20+ | Express 5 | OpenAI SDK | Helmet | Rate limiting | Stable JSON errors

DELIVERY	PROVIDER	SECURITY	QUALITY
Authenticated REST API	OpenAI Responses API	Bearer auth + rate limits	15 tests + multi-version CI

Architecture

EDGE	APPLICATION	AI ADAPTER	OPERATIONS
Helmet, 32 KB JSON limit, IP rate limit, bearer authentication.	Question schema, prompt boundaries, bundled policy context, response normalization.	Responses API, AbortController timeout, transient retry, SDK error mapping.	Live and ready health checks, structured logs, graceful shutdown.

HTTP surface

METHOD	ROUTE	PURPOSE
GET	/health/live	Process liveness
GET	/health/ready	Required-secret readiness
POST	/support/ask	Authenticated support answer

Public error contract

400	invalid_request / invalid_json	401	unauthorized
413	payload_too_large	429	rate_limited
502	provider_error	503/504	readiness, provider limit, or timeout

Security and resilience

- Separate inbound and provider secrets	- Per-attempt provider timeout
- Timing-safe authentication	- Bounded transient retries
- Bounded request size and question length	- Redacted public errors
- Configurable proxy trust	- Per-process rate limiting

Verification

15 tests exercise application logic and the local HTTP surface without paid provider calls. CI installs locked dependencies and runs the full check on Node.js 20, 22, and 24.

Run locally

npm ci	npm run check	npm start
--------	---------------	-----------

Production rollout adds managed secrets, TLS, centralized observability, distributed rate limiting, approved policy content, and representative quality evaluations.